W2-PM-FINAL | CYBERSECURITY & ETHICAL HACKING | NETWORKWALKS

PENETRATION TESTING REPORT

Footprinting & Network Scanning Phases

Engagement Field	Assessment Details
Pentester Name	Giselle Lawrence Coutinho
Program / Batch	Batch B084 — Networkwalks Cybersecurity & Ethical Hacking Internship
Assessment Date	11–12 November 2026
Modules Completed	W2-PM1 (Multiple Kali Linux Footprinting Tools) & W2-PM5 (Zenmap Scanning)
Client / Target Scope	1. `networkwalks.com` (Authorized Domain) 2. Local Wi-Fi LAN Subnet
Authorization Secured	Yes — Written authorization secured for `networkwalks.com`; local LAN owned by assessor
Phases Covered	Phase 1: Reconnaissance & Footprinting Phase 2: Scanning & Network Discovery Phases 3–5: Upcoming Internship Modules

1. Liability Disclaimer

All reconnaissance and scanning activities documented in this report were performed strictly on systems and domains where explicit written authorization was secured (`networkwalks.com`) or on local network infrastructure owned directly by the assessor. These materials are compiled solely for educational and defensive security research purposes.

Unauthorized scanning, enumeration, or access against third-party systems is illegal and can result in severe legal penalties, criminal prosecution, and civil liability. The instructor, authors, and Networkwalks assume no responsibility for misuse of the techniques demonstrated herein.

2. Introduction

This report documents the Week 2 practical assessment (`W2-PM-FINAL`) of the Networkwalks Cybersecurity & Ethical Hacking Internship (Batch B084). The engagement bridges two foundational assessment stages: passive external footprinting of `networkwalks.com` using Kali Linux tools (`W2-PM1`) and active local network discovery using Zenmap (`W2-PM5`).

All exercises were executed directly from the assessor's personal laptop using a Kali Linux virtual machine (VirtualBox) for command-line OSINT/web profiling and Zenmap (Nmap GUI) for local subnet discovery. Each section details the exact commands executed, empirical observations, risk evaluations, and supporting visual evidence.

3. Tools Used

Tool / Environment	Phase	Operational Purpose
Kali Linux (VirtualBox)	Phase 1	Penetration testing environment used to execute external CLI footprinting tools.
`whois`	Phase 1	Query domain registration metadata, registrar details, status locks, and name servers.
`nslookup`	Phase 1	Perform DNS resolution to map the target domain name to its public IPv4 address.
`dnsrecon`	Phase 1	Enumerate comprehensive DNS zone records (SOA, NS, MX, A, TXT/SPF, SRV) and DNSSEC status.
`curl -I`	Phase 1	Retrieve and inspect raw HTTP/2 response headers, cookies, and API link headers.
`whatweb`	Phase 1	Fingerprint web server software, CMS versions, plugins, frontend libraries, and metadata.
`wafw00f`	Phase 1	Detect and identify perimeter Web Application Firewalls (WAFs) protecting the web application.
Zenmap (Nmap 7.993)	Phase 2	Execute local subnet host discovery (`nmap -sn`), capture MAC addresses, and generate network topology maps.

4. Activities Performed

4.1 Phase 1: Passive Footprinting & Web Fingerprinting (Kali Linux)

Using six specialized Kali Linux reconnaissance utilities against `networkwalks.com`, publicly accessible domain, DNS, and web server attributes were systematically enumerated without intrusive exploitation:

- **Domain Registration Lookup (`whois networkwalks.com`):** Confirmed registration through GoDaddy.com, LLC (IANA ID 146), created on 2019-11-06 and valid through 2027-11-06. Identified four ICANN EPP client protection locks (`clientDeleteProhibited` , `clientRenewProhibited` , `clientTransferProhibited` , `clientUpdateProhibited`), authoritative HostGator name servers (`NS6135.HOSTGATOR.COM` , `NS6136.HOSTGATOR.COM`), and an `unsigned` DNSSEC configuration.
- **DNS Name Resolution (`nslookup networkwalks.com`):** Queried Google Public DNS (`8.8.8.8`) and resolved `networkwalks.com` to the public IPv4 address `192.232.216.135` .
- **Comprehensive DNS Enumeration (`dnsrecon -d networkwalks.com`):** Enumerated SOA, NS, MX (`mail.networkwalks.com` at `192.232.216.135`), A, TXT, and eight `_autodiscover._tcp` SRV records pointing to `cpanelemaildiscovery.cpanel.net` . Also identified DNS software version banners (`Bind 9.16.23-RH`) on both name servers, an SPF policy (`v=spf1 +a +mx +ip4:50.87.144.87 +include:websitewelcome.com ~all`), and confirmed the absence of DNSSEC records.

- **HTTP Header Inspection (`curl -I https://networkwalks.com`):** Confirmed HTTP/2 `200 OK` responses served by `Apache` alongside `x-nginx-cache: WordPress` and `x-endurance-cache-level: 0`. Observed `Secure` and `HttpOnly` flags properly set on the `__wpdm_client` session cookie, alongside exposed WordPress REST API endpoints (`/wp-json/` and `/wp-json/wp/v2/pages/53`) in the `link` header and a `no-referrer-when-downgrade` referrer policy.
- **Web Technology Fingerprinting (`whatweb networkwalks.com`):** Identified HTTP-to-HTTPS `301` redirection, Apache HTTP Server, WordPress `7.1.4`, WordPress Download Manager `3.3.76`, Bootstrap `7.1.4`, jQuery `3.7.1`, Google Tag Manager, HTML5, and public contact email `info@networkwalks.com`.
- **Web Application Firewall Detection (`wafw00f networkwalks.com`):** Sent two HTTP probe requests and confirmed that `https://networkwalks.com` is actively protected behind a **ModSecurity (SpiderLabs)** Web Application Firewall.

4.2 Phase 2: Local Network Discovery & Topology Mapping (Zenmap)

For the second phase, active host discovery was performed on the assessor's personal local Wi-Fi subnet (`192.168.0.0/24`) using Zenmap (Nmap 7.993) with the **Ping Scan** profile (`nmap -sn 192.168.0.0/24`). In accordance with lab scope guidelines, testing was restricted strictly to non-intrusive ICMP/ARP host discovery without port or service probing.

Nmap scanned all 256 IP addresses in 12.56 seconds and identified **5 active hosts** on the local wireless network:

IPv4 Address	Hostname / Device Role	MAC Address & Vendor	Latency / Status
`192.168.0.1`	Local Default Gateway / Router	`5C:4D:BF:99:EE:86` (ZTE)	Up (0.19s latency)
`192.168.0.37`	`vivo-1951` (Mobile Endpoint)	`EE:BC:69:41:9D:7A` (Unknown / Randomized)	Up (0.73s latency)
`192.168.0.154`	`Giselle-s-M53` (Mobile Endpoint)	`8E:F8:43:07:10:D2` (Unknown / Randomized)	Up (0.30s latency)
`192.168.0.216`	`Giselle_Laptop` (Scanning Host)	Local Host Interface	Up (Localhost)
`192.168.0.251`	`iPhone` (Mobile Endpoint)	`CA:7A:91:37:81:54` (Unknown / Randomized)	Up (0.46s latency)

Following host discovery, Zenmap's **Topology** view and **Topology Legend** were enabled to inspect the radial network layout, illustrating direct wireless connections radiating from `localhost` (`Giselle_Laptop`) to the gateway and peer client devices.

5. Risk Analysis & Impact Assessment

The table below summarizes the security observations identified across both reconnaissance phases, their supporting evidence, potential operational impact, and assigned risk severity:

#	Observation / Finding	Evidence Collected	Potential Security Impact	Risk Level
1	**CMS & Plugin Version Disclosure**	`whatweb` identified WordPress `7.1.4` and WordPress Download Manager `3.3.76` via meta generator tags.	Exposing exact CMS and plugin version numbers enables attackers to cross-reference public CVE databases for targeted exploits.	**Medium**
2	**DNS Software Banner & Unsigned DNSSEC**	`dnsrecon` exposed `Bind 9.16.23-RH` on both name servers and reported `unsigned` DNSSEC status.	Bind version disclosure aids targeted DNS server profiling; lack of DNSSEC leaves DNS responses vulnerable to spoofing or cache poisoning.	**Medium**
3	**WordPress REST API & Server Banner Exposure**	`curl -I` returned `server: Apache`, cache headers, and `link` headers exposing `/wp-json/` endpoints.	Reveals backend architecture and active REST API routes that can be queried for user or content enumeration.	**Low**
4	**Origin Server IP & Mail Infrastructure Mapping**	`nslookup` and `dnsrecon` mapped web and mail services to `192.232.216.135` and cPanel autodiscover hosts.	Provides attackers with direct IP targets and mail routing infrastructure for potential perimeter bypass or phishing pretexting.	**Low**
5	**WAF Technology Identification**	`wafw00f` positively fingerprinted `ModSecurity (SpiderLabs)` in two requests.	While ModSecurity provides strong active defense, identifying the specific WAF product allows adversaries to tailor rule-evasion payloads.	**Low**
6	**Local Wi-Fi Host & Hostname Visibility**	Zenmap `nmap -sn` discovered 5 active hosts on `192.168.0.0/24`, exposing device hostnames and gateway MAC.	Unmonitored local subnets allow any connected client to enumerate peer devices; unauthorized endpoints could go undetected without regular audits.	**Medium**

> **Assessment Scope Note:** Risk Key — **High** | **Medium** | **Low**. All items listed above represent informational reconnaissance observations rather than confirmed exploitable vulnerabilities. No active exploitation or vulnerability validation was performed during Week 2.

6. Security Recommendations

1. **Suppress CMS & Plugin Version Banners:** Remove WordPress meta generator tags and plugin version strings from public HTML source and HTTP headers to prevent automated version fingerprinting.
2. **Maintain Patch Management Cadence:** Keep WordPress core, WordPress Download Manager, and underlying Apache/PHP packages updated against current security advisories.
3. **Harden HTTP Response Headers:** Strip verbose server and caching banners (such as `x-endurance-cache-level` and `x-nginx-cache`), restrict unnecessary unauthenticated `/wp-json/` REST API routes, and upgrade `Referrer-Policy` to `strict-origin-when-cross-origin`.
4. **Enable DNSSEC & Hide BIND Version Strings:** Configure BIND name servers (`version "none";`) to suppress software banners and enable DNSSEC signing at the registrar/DNS host to protect domain integrity.
5. **Maintain & Tune ModSecurity WAF Rules:** Keep the ModSecurity (SpiderLabs) WAF active with updated OWASP Core Rule Set (CRS) signatures and review WAF logs periodically for reconnaissance anomalies.
6. **Conduct Periodic Internal Asset Discovery:** Run scheduled local network scans to maintain an up-to-date inventory of authorized devices and immediately investigate unknown MAC addresses or hostnames.
7. **Enforce Client Isolation & Network Segmentation:** Enable wireless client isolation on guest/untrusted SSIDs where device-to-device communication is unnecessary, and maintain current network topology documentation.

7. Conclusion

During Week 2 of the Networkwalks Cybersecurity & Ethical Hacking Internship (Batch B084), end-to-end reconnaissance and network discovery workflows were successfully executed from a personal workstation using Kali Linux and Zenmap. Passive OSINT and web profiling tools (`whois`, `nslookup`, `dnsrecon`, `curl`, `whatweb`, and `wafw00f`) demonstrated how much architectural, DNS, and CMS metadata is publicly observable prior to any active testing.

Complementing external footprinting with Zenmap host discovery (`nmap -sn`) and radial topology mapping on `192.168.0.0/24` highlighted the importance of internal device visibility. Together, both exercises reinforce that disciplined information gathering, clear technical documentation, and strict adherence to authorized scope are foundational to professional security assessments.

8. Evidences Collected

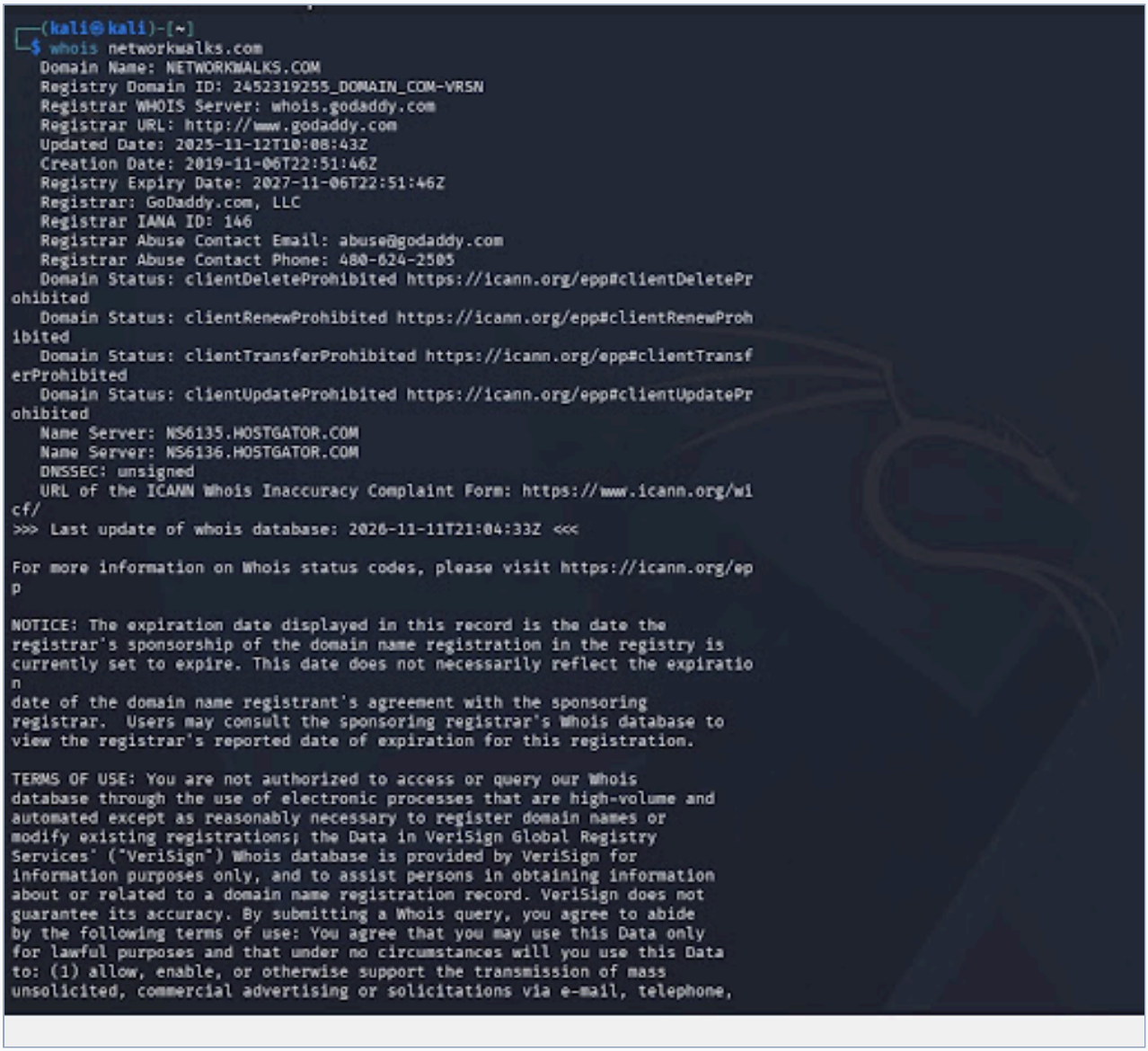


Figure 1: WHOIS domain registration query for networkwalks.com showing GoDaddy registrar details, ICANN EPP locks, and HostGator name servers.

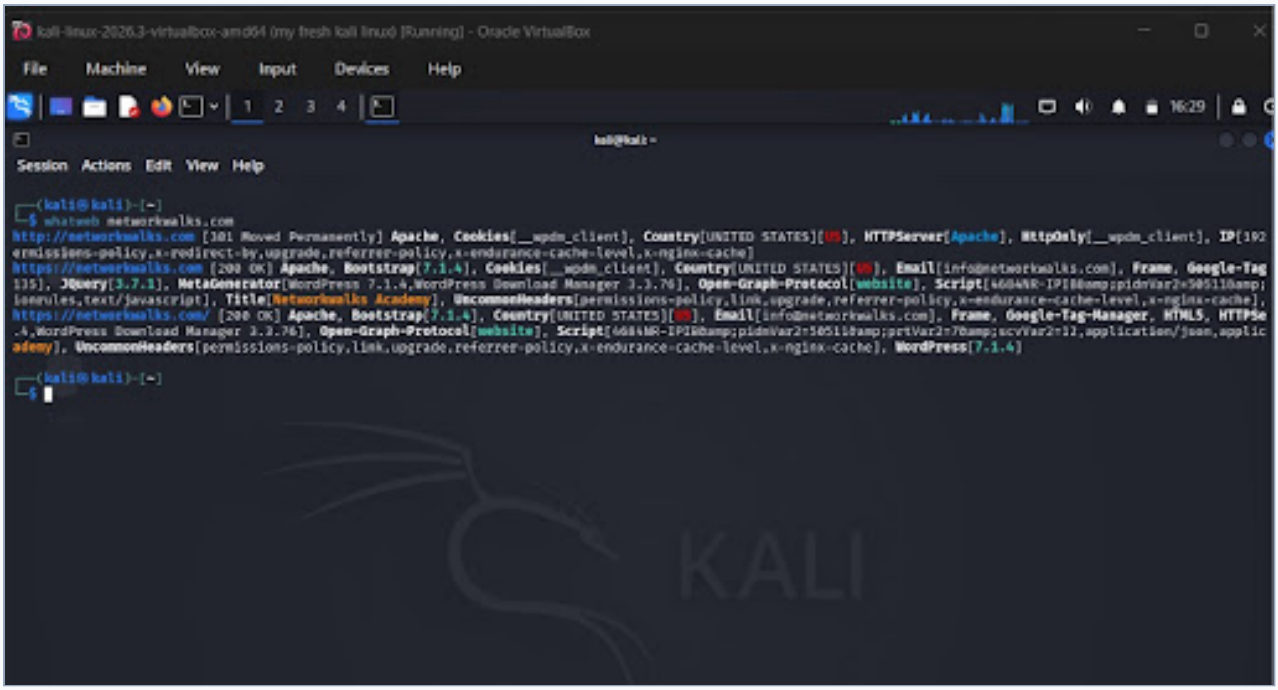


Figure 2: WhatWeb technology fingerprinting output identifying Apache, WordPress 7.1.4, WordPress Download Manager 3.3.76, Bootstrap 7.1.4, and jQuery 3.7.1.

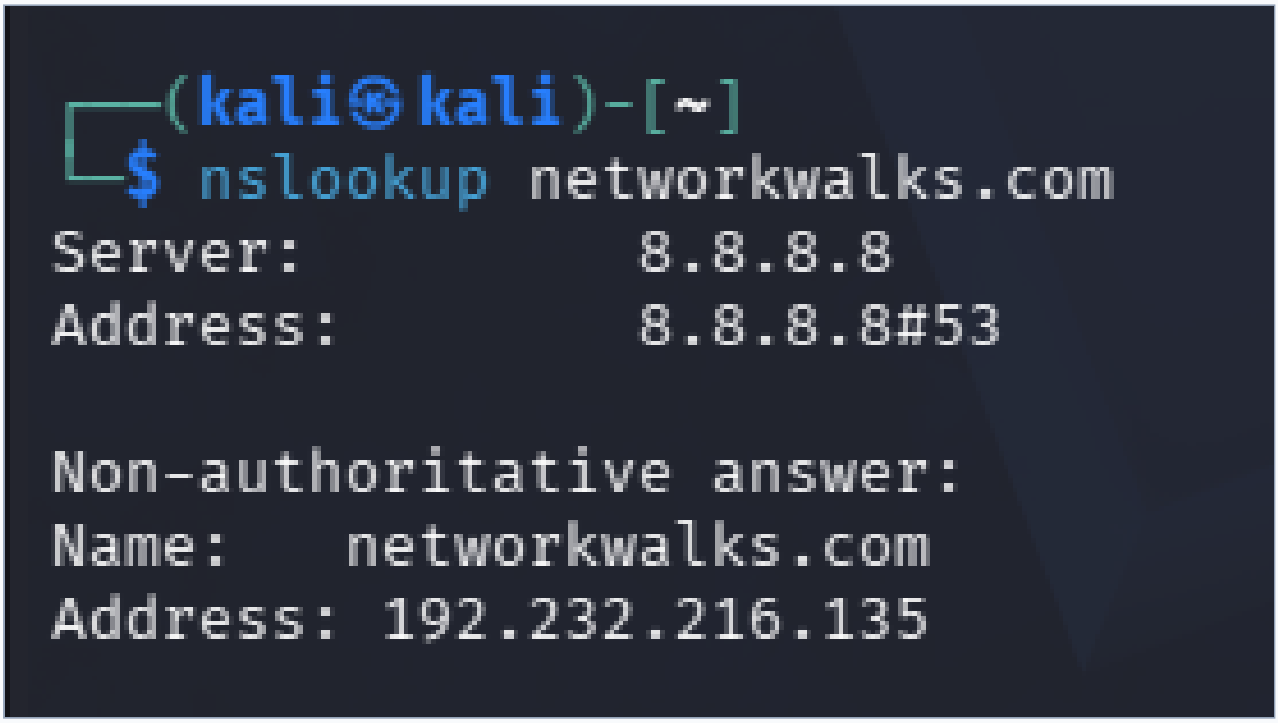


Figure 3: DNS A-record resolution via nslookup resolving networkwalks.com to 192.232.216.135 using resolver 8.8.8.8.



Figure 4: HTTP/2 response header inspection via curl -I revealing Apache/Nginx caching headers, HttpOnly cookie flags, and WordPress REST API link headers.



Figure 5: WAF fingerprinting output via wafw00f v2.4.2 confirming protection by ModSecurity (SpiderLabs) WAF.

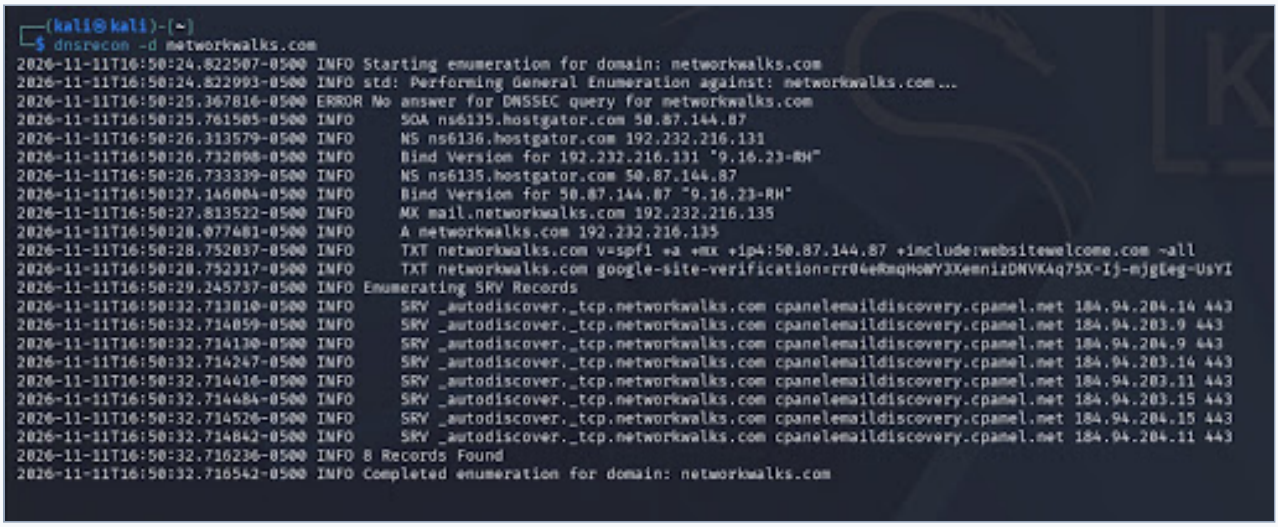


Figure 6: Comprehensive DNS enumeration via dnsrecon detailing SOA, NS, MX, A, TXT/SPF, cPanel autodiscover SRV records, and Bind 9.16.23-RH banners.

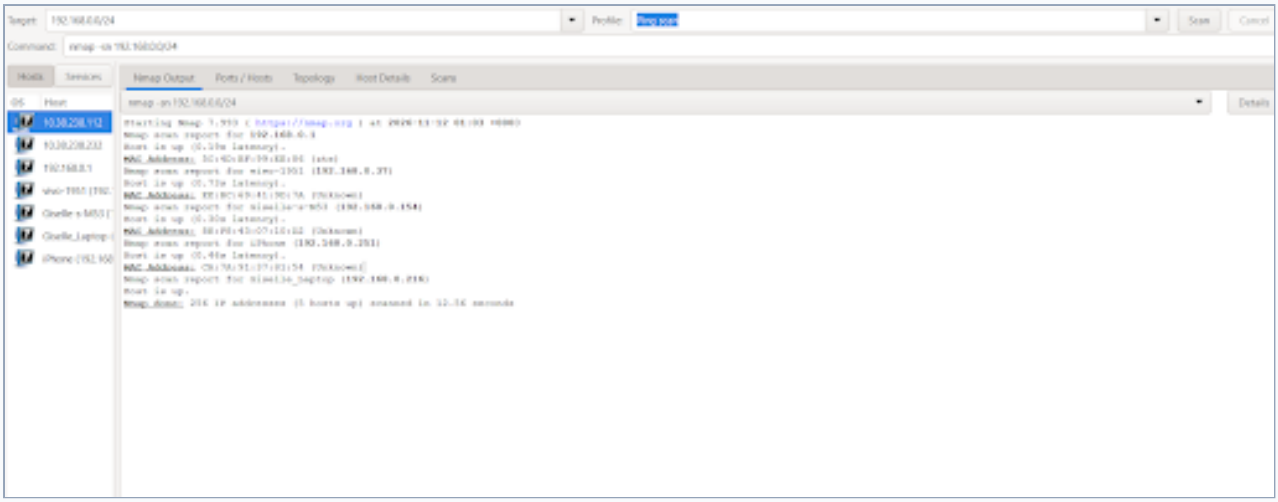


Figure 7: Zenmap Ping Scan (nmap -sn 192.168.0.0/24) discovering 5 active hosts, latencies, hostnames, and MAC addresses on the local Wi-Fi subnet.

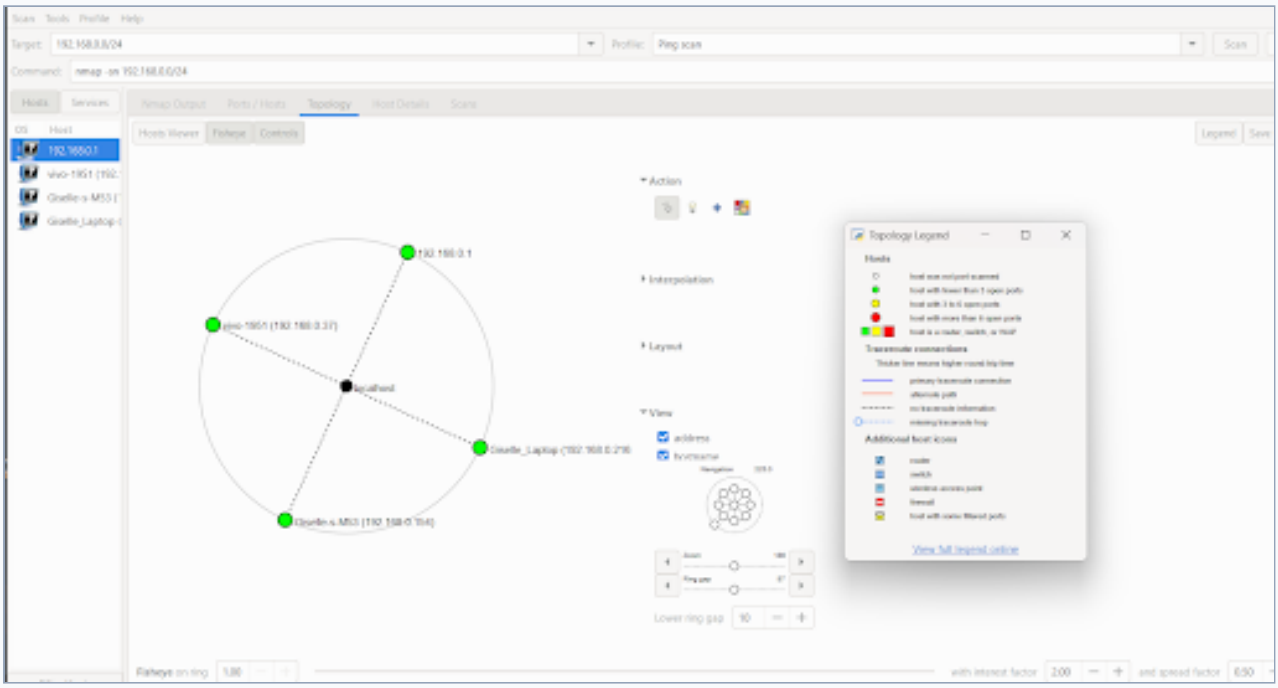


Figure 8: Zenmap radial network topology diagram and legend illustrating device relationships between Giselle_Laptop (localhost), the ZTE gateway (192.168.0.1), and wireless client endpoints.